

Security & Compliance Document

Security architecture, access control model, data protection, and assessment of the delivered security model

DOCUMENT REFERENCE	CB-SEC-2026-008
VERSION	1.0
DATE OF ISSUE	2026-07-18
PREPARED FOR	CareBridge Health
PREPARED BY	CareBridge Engineering Team
CLASSIFICATION	Confidential

Table of Contents

1 Introduction	3
1.1 Purpose and Scope	3
1.2 What the System Holds	3
2 Security Architecture	4
2.1 Defence Layers	4
2.2 Authentication	4
2.3 Authorisation	5
2.4 Access Control Matrix	5
2.5 Data Protection	6
2.6 Input Handling	7
2.7 Accountability	7
3 Security Findings	9
3.1 High	9
3.2 Medium	9
3.3 Low and Informational	10
4 Operational Security	12
4.1 Secret Management	12
4.2 Account Hygiene	12
4.3 Approval as a Security Control	12
4.4 Incident Response	12
5 Data Protection Practice	14
5.1 Data Minimisation	14
5.2 Retention	14
5.3 Subject Access and Erasure	14
5.4 Third-Party Processors	14
6 Recommendations	16
6.1 Immediate — Before Wider Release	16
6.2 Short Term — Within the First Quarter	16
6.3 Medium Term	16
6.4 Closing Statement	17

1. Introduction

1.1 Purpose and Scope

This document describes how CareBridge protects the data it holds and states its security limitations without qualification.

It is written to be usable by a non-specialist reader making a risk decision, and by an engineer implementing the recommendations. Where the system does not do something, that is stated plainly rather than described in terms that imply it does.

1.2 What the System Holds

Understanding the sensitivity of the data determines how seriously each finding should be taken. CareBridge holds the following categories.

Category	Examples	Sensitivity
Patient identifying data	Name, national identity number, date of birth, gender, telephone number, area, guardian name and relation	High. The identity number is the strongest identifier and is the only field encrypted at the field level.
Patient clinical data	Presenting symptoms, clinical summary, diagnosis, clinical notes timeline, uploaded reports and scans	High. This is health information about identifiable individuals.
Professional credentials	Registration certificates, identity documents, licences uploaded at registration	High. These are identity documents belonging to third parties.
Commercial data	Bill amounts, commission rates, negotiated per-party terms, settlement records, payout receipts	Medium to high. Individually negotiated rates are commercially confidential between the parties.
Account data	Email addresses, telephone numbers, password hashes, session credentials	High. Compromise grants access to everything above.
Operational data	Bed counts, test catalogues, departments, response statistics	Low.

THIS IS A HEALTH DATA PLATFORM

The combination of an identifiable patient and their clinical condition is the most sensitive data category the platform handles. Every recommendation in this document should be weighed against that, rather than against the standard for a general business application.

2. Security Architecture

2.1 Defence Layers

TRANSPORT	HTTPS enforced by both hosting platforms
BROWSER	Protective response headers content type, framing, and referrer policy
EDGE	Cross-origin allowlist Rate limit on authentication endpoints
IDENTITY	Signed access credential, 1 hour Rolling renewal credential, 30 days Renewal refused for inactive accounts
AUTHORISATION	Role guard per endpoint (administrator passes unconditionally)
APPLICATION	Schema validation, enumerated values, format checks, state transition rules
DATA	Password hashing (cost 12) Patient identity encrypted at field level Uniqueness enforced at the database
ACCOUNTABILITY	Audit log of administrative actions

Figure 1: Security controls by layer

2.2 Authentication

Control	Implementation
Password storage	Salted hashing at cost factor 12. Plaintext passwords are never stored and cannot be recovered from the database.
Password strength	Minimum eight characters, enforced at registration and reset.
Email verification	A six-digit code that expires after ten minutes and is invalidated after five failed attempts.
Approval gate	Every account is created pending and cannot sign in until an administrator activates it. Registration alone grants no access.
Session credentials	A one-hour access credential carrying identity and role, and a thirty-day renewal credential carrying identity only, signed with separate keys.
Rolling renewal	Each renewal issues a fresh pair, so a captured renewal credential has a bounded useful life if the legitimate user continues working.

Control	Implementation
Status enforcement at renewal	Renewal is refused for an account that is not active. This is the mechanism by which suspension takes effect on an existing session, within one hour.
Password reset	A single-use, time-limited emailed link. Requesting a reset for an unregistered address returns success, so registered addresses cannot be enumerated.
Sign-in notification	The account holder is notified of each sign-in, giving a chance to notice unauthorised access.
Rate limiting	Thirty requests per minute per client address across registration, sign-in, renewal, code issue and verification, and password reset.

THERE IS NO CREDENTIAL REVOCATION LIST

A renewal credential remains cryptographically valid for its full thirty-day lifetime. The only server-side control is the account status check performed at renewal. Suspending the account is therefore the effective revocation mechanism and takes effect within one hour. A revocation list would allow immediate invalidation and is recommended in section 6.

2.3 Authorisation

Every endpoint declares the role permitted to call it, and a guard enforces this before the handler runs. One exception is deliberate and significant: the administrator role passes the guard unconditionally, before the endpoint's own role list is consulted.

AN ADMINISTRATOR ACCOUNT IS AN UNRESTRICTED ACCOUNT

The administrator bypass means every endpoint in the system is administrator-reachable, including every patient record, every clinical note, every commercial term, and every financial record. There is no read-only administrator, no scoped administrator, and no separation between operational and financial administration. The controls that follow from this are: issue administrator accounts sparingly, make each one a named individual rather than a shared login, and review the audit log regularly — it is the only record of what an administrator did.

2.4 Access Control Matrix

Data	Consultant	Hospital	Laboratory	Admin
Own profile	Read, write	Read, write	Read, write	Read, write
Another party's profile	None	None	None	Read, write
Own referrals	Read, write while unadmitted	Read, write on referrals directed to them	Read, write on referrals directed to them	Read, write, delete on all
Another party's referrals	None	None	None	Full

Data	Consultant	Hospital	Laboratory	Admin
Patient identity number	On own referrals	On referrals directed to them	On referrals directed to them	On all
Clinical notes	Read, write on own referrals	Read, write on their referrals	Not applicable	Read on all
Verification documents	Own only	Own only	Own only	All
Bed inventory	Read via recommendations	Read, write own	Not applicable	Read, write all
Test catalogue	Read via recommendations	Not applicable	Read, write own	Read, write all
Commercial terms	Read own	Read own	Read own	Read, write all
Settlements	Own payouts, confirm receipt	Own settlements	Own settlements	All, verify and release
Financial ledger	Own earnings	Own ledger	Own ledger	All
Platform configuration	None	None	None	Read, write
Audit log	None	None	None	Read, export
Team accounts	None	Own team	Own team	All

OWNER AND TEAM MEMBER ACCOUNTS SHARE PERMISSIONS

Within a facility, the account created at registration and the team member accounts it creates have the same permissions. The distinction exists in the data and is used to authorise deletion — a member cannot remove an account above them in the creation chain — but not to restrict features. A hospital receptionist can therefore see the hospital's commercial terms and financial ledger. A facility-level administrator tier with distinct privilege would be required to restrict this.

2.5 Data Protection

Control	Implementation	Assessment
Passwords	Salted hashing at cost 12.	Appropriate. Current best practice.
Patient identity numbers	Encrypted at the field level with a fresh initialisation vector per value, applied transparently at the schema level.	Confidentiality is provided. Tamper detection is not — see below.
Data in transit	HTTPS enforced by both hosting platforms.	Appropriate.
Data at rest	Provided by the database and file storage providers.	Appropriate, subject to the provider's own controls.

Control	Implementation	Assessment
Uploaded documents	Held by the file storage provider, encrypted at rest by that provider.	Reachable by direct link without an authentication check — see section 3.
Notification payloads	Personal data — email, telephone, and name — is stripped before storage.	Good practice, and deliberately done.
Other clinical and patient fields	Stored without field-level encryption.	Names, dates of birth, symptoms, diagnoses, and clinical notes are stored in readable form. Protection rests on database access control and role-based authorisation.

PATIENT IDENTITY ENCRYPTION PROVIDES CONFIDENTIALITY BUT NOT INTEGRITY

The encryption mode in use conceals the value but carries no authentication tag, so modification of stored ciphertext would not be detected on decryption — it would produce a different value or a decryption failure rather than a recognisable tamper signal. Migrating to an authenticated mode is recommended in section 7. It requires a data migration and should be planned rather than applied as a configuration change.

2.6 Input Handling

Control	Implementation
Schema validation	Type, requiredness, and enumerated values are enforced at the data layer, so an invalid value cannot be persisted even if a handler omits a check.
Format validation	National identity numbers and telephone numbers are validated against locale-specific patterns.
Injection resistance	Queries are constructed through the data mapper rather than by string concatenation.
File type validation	Uploads are checked on both file extension and declared content type, and limited to images and PDF documents.
File size limit	Five megabytes per file.
State transition rules	Referral, admission, and settlement transitions are validated, so a settlement cannot skip verification and a closed referral cannot be reopened by an ordinary request.

2.7 Accountability

Administrative actions are recorded with the acting user, the action, the affected record and its type, the network address, and the client used. The log is searchable and exportable by an administrator.

THE AUDIT LOG IS APPEND-ONLY BY CONVENTION, NOT BY ENFORCEMENT

Nothing in the application deletes audit entries, but nothing prevents an administrator with database access from doing so. Where the log is relied upon as evidence, periodic export to storage outside the application database is recommended.

3. Security Findings

The following are the security weaknesses in the delivered system. Each is stated with its actual exposure — neither minimised nor overstated — and its recommended remedy.

3.1 High

Ref	Finding
SEC-H-01	The file upload endpoint does not require authentication. It is the only unauthenticated write endpoint besides the payment callback, which is protected by signature verification instead.

Exposure: anyone able to reach the API can upload a file. Uploads are constrained to images and PDF documents of five megabytes or less, checked on both extension and declared content type, and an uploaded file has no effect until an authenticated user attaches it to a record. The realistic risks are therefore consumption of storage quota and use of the storage account to host arbitrary files, rather than direct compromise of platform data.

Remedy: apply the existing authentication guard to the endpoint. The client already sends a credential on every request, so no client change is required. This is a small change and is the highest-priority action in this package.

3.2 Medium

Ref	Finding	Exposure	Remedy
SEC-M-01	Rate limiting applies only to authentication endpoints.	The remainder of the interface, including the administrative surface and file upload, has no protection against automated abuse or scraping by an authenticated party.	Apply a global limit with a generous ceiling, retaining the tighter limit on authentication.
SEC-M-02	Patient identity encryption provides no tamper detection.	Modification of stored ciphertext would not be detected. This requires database access to exploit, so it is a defence-in-depth weakness rather than a direct exposure.	Migrate to an authenticated encryption mode, with a planned data migration.
SEC-M-03	Uploaded documents are reachable by direct link without an authentication check.	Anyone holding a document address can retrieve it. Addresses are long and unguessable and are disclosed only to authorised users, but this is obscurity rather than access control — and the documents include identity documents and patient reports.	Move to time-limited signed addresses generated per authorised request.
SEC-M-04	One-time-password state is held in process memory.	Verification codes are lost on restart, and the backend cannot be scaled beyond one instance without codes failing intermittently. Availability rather than confidentiality.	Move the store to a shared cache.

Ref	Finding	Exposure	Remedy
SEC-M-05	The cross-origin setting defaults to permissive when left blank.	If unset in production, the API accepts requests from any origin, weakening protection against cross-site request abuse.	Set explicitly at deployment. Included in the go-live checklist.
SEC-M-06	There is no credential revocation list.	A renewal credential remains valid for thirty days. Suspending the account is the only revocation, effective within one hour.	Introduce a revocation list, or shorten the renewal credential lifetime.
SEC-M-07	Clinical and patient fields other than the identity number are stored without field-level encryption.	Anyone with database access can read names, dates of birth, symptoms, diagnoses, and clinical notes.	Restrict and monitor database access as the primary control. Extending field-level encryption to clinical fields is possible but would prevent searching those fields, which should be weighed deliberately.
SEC-M-08	No integration test coverage of the authentication and authorisation middleware.	A change weakening a role boundary would not be detected automatically.	Add integration tests over the guards.

3.3 Low and Informational

Ref	Finding	Remedy
SEC-L-01	The administrator role bypasses all endpoint role checks.	Intentional. Mitigate operationally: few administrators, each a named individual, with regular audit log review. A scoped administrator role is a possible future enhancement.
SEC-L-02	There is no application-level error handler, so error response shapes are consistent by convention rather than by enforcement.	Add a central handler that returns a uniform shape and guarantees no internal detail is disclosed.
SEC-L-03	No request body size limit beyond the framework default.	Set an explicit limit.
SEC-L-04	The audit log is append-only by convention only.	Export periodically to storage outside the application database where the log is relied upon as evidence.
SEC-L-05	A superseded wallet crediting module remains in the codebase.	Remove it. Dormant financial code is a liability if reconnected by mistake.
SEC-L-06	The payment gateway return address defaults to a path that does not exist.	Set explicitly if the payment integration is activated. Left at the default, callbacks are not received.

Ref	Finding	Remedy
SEC-L-07	There is no automatic session inactivity timeout.	Sessions renew transparently for as long as the account remains active. A configurable inactivity timeout is recommended.

4. Operational Security

4.1 Secret Management

- All secrets are supplied as environment variables and none is committed to the repository.
- Every shared secret should be rotated by the client at handover, so production runs on secrets known only to the client.
- The two token signing keys can be rotated freely; the only effect is that all users are signed out.
- **The encryption key must never be rotated without a planned data migration** — doing so renders existing encrypted patient identity numbers permanently unreadable.
- Keep an offline inventory of every configuration value in a password manager accessible to more than one person, since hosting platform variables are not covered by database backups.

4.2 Account Hygiene

- Change the seeded administrator password immediately after first sign-in.
- **Create a named administrator account for each operator rather than sharing one login** — audit entries record the acting account, so a shared account makes the log far less useful.
- Remove administrator accounts promptly when someone leaves. There is no automatic expiry.
- Review the administrator list periodically against the people who should have unrestricted access.

4.3 Approval as a Security Control

REGISTRATION APPROVAL IS THE PLATFORM'S PRIMARY ADMISSION CONTROL

Approving an application admits an organisation to a platform holding patient data and money. The uploaded certificate should be legible and the registration number should match it. Approving an application whose documents cannot be read defeats the control entirely, and it is the only verification step in the system — nothing is checked against an external registry.

4.4 Incident Response

The platform has no automated incident detection. In the event of a suspected compromise the following sequence is recommended.

1. Suspend the affected account immediately. This is the effective session revocation and takes effect within one hour.
2. Review the audit log for actions by that account, and export the relevant period before making further changes.
3. **If an administrator account is implicated, rotate both token signing keys** — this signs out every user — and review all administrative activity for the period.
4. If the database may be affected, rotate the database password and review recent records for unexpected modification.

5. If patient data may have been disclosed, follow the client's own data protection obligations for notification. The platform cannot determine on its own what was read.
6. Record the incident and the response, including timings, so the sequence can be improved.

A GAP WORTH ACKNOWLEDGING

The audit log records administrative actions, not data reads. It is therefore possible to establish what an administrator changed, but not what they viewed. Where read accountability matters, read logging on sensitive records would need to be added.

5. Data Protection Practice

5.1 Data Minimisation

- Notification payloads are stripped of email, telephone, and name before storage, so the notification collection holds no personal data.
- The renewal credential carries only the user identity, not the role or name.
- Registration collects only what is needed for verification and matching.

5.2 Retention

THE PLATFORM IMPLEMENTS NO RETENTION POLICY

Referrals, patient data, clinical notes, uploaded documents, and audit entries are retained indefinitely. Deleting an account does not remove the patient data associated with referrals it created. If the client is subject to a retention obligation — whether a maximum period under data protection law or a minimum period under medical record rules — a retention and purge policy will need to be defined and implemented. It does not exist today.

5.3 Subject Access and Erasure

There is no self-service mechanism for a data subject to request their data or its erasure. An administrator can locate a patient's referrals and export them as documents, and can delete a referral, but deletion is permanent, removes the associated financial history, and requires three confirmations. If the client is subject to subject access or erasure obligations, a defined procedure — and probably tooling — will be required.

5.4 Third-Party Processors

Processor	Data it holds	Consideration
Database provider	All application data, including patient and clinical data	The primary processor. Confirm the hosting region is acceptable and that the provider agreement covers health data.
File storage provider	Verification documents, identity documents, patient reports, receipts	Holds identity documents and clinical reports. Confirm the hosting region and retention terms.
Email provider	Email addresses, and message content including verification codes and notification text	Notification content includes referral references. Confirm the provider agreement.
Messaging provider	Telephone numbers and message content, where enabled	Only where the client activates it.
Payment gateway	Transaction references and amounts, where enabled	Only where the client activates it. No card data passes through the platform.

Processor	Data it holds	Consideration
Backend host	Application memory and logs in transit	Logs should not contain patient data; confirm before enabling verbose logging.
Frontend host	Static assets only	No application data.

6. Recommendations

6.1 Immediate — Before Wider Release

#	Action	Effort
1	Place the file upload endpoint behind authentication.	Small
2	Set the cross-origin allowlist explicitly to the production frontend address.	Trivial
3	Rotate every shared secret inherited from the development team.	Small
4	Change the seeded administrator password and create named administrator accounts.	Trivial
5	Confirm automated database backups are enabled and verify a restore.	Small

6.2 Short Term — Within the First Quarter

#	Action	Effort
6	Apply a global rate limit, retaining the tighter authentication limit.	Small
7	Add a central error handler guaranteeing a uniform response shape with no internal detail.	Small
8	Set an explicit request body size limit.	Trivial
9	Remove the superseded wallet crediting module.	Small
10	Add integration tests over the authentication and authorisation guards.	Medium
11	Add an uptime check with alerting against the health endpoint.	Small
12	Move uploaded documents to time-limited signed addresses.	Medium

6.3 Medium Term

#	Action	Effort
13	Migrate patient identity encryption to an authenticated mode, with a data migration.	Medium
14	Move one-time-password state to a shared cache, removing the restart fragility.	Medium
15	Introduce a credential revocation list, or shorten the renewal credential lifetime.	Medium
16	Define and implement a data retention and purge policy.	Medium
17	Define a subject access and erasure procedure, with supporting tooling.	Medium

#	Action	Effort
18	Consider a scoped or read-only administrator role, reducing the number of unrestricted accounts.	Medium
19	Consider read logging on patient and clinical records, if read accountability is required.	Large

6.4 Closing Statement

The delivered system implements the security controls appropriate to a platform of this kind: hashed passwords, an approval gate before any access is granted, role-based authorisation on every endpoint, field-level encryption of the strongest patient identifier, validated input, and an audit trail of administrative action. Its weaknesses are known, documented above without omission, and each has a defined remedy.

One finding — the unauthenticated file upload endpoint — should be corrected before the platform is opened more widely. The remainder are improvements to be scheduled rather than blockers.